



Third-Party ICT Risk Management Guideline

Version: 2.0

Valid From Date: 19.08.2026

Last Review Date: 14.08.2026

Notes: This written rule uses gender-neutral and inclusive language. Whenever possible, the generic masculine is avoided and all employees of any gender identity (m/f/d) are addressed.

Content changes compared to the previous document version are highlighted in color.

Content

1. Purpose, Objectives and Basis	3
1.1. Purpose and Objectives	3
1.2. Basis of this Guideline	4
2. Functional Scope and Target Groups	5
2.1. Functional scope of applicability	5
2.2. Target groups	5
2.3. Transition period	6
3. Definitions	7
3.1. Requirements	7
3.2. Explanation of requirements and key definitions	8
4. Requirements	9
4.1. Requirements	9
5. Roles and Responsibilities	28
5.1. Creator	28
5.2. Guideline Owner	28
6. Appendix	29
6.1. Contact Information	29
6.2. Document History	29
6.3. Related Written Rules	29
6.4. Abbreviations	30

1. Purpose, Objectives and Basis

1.1. Purpose and Objectives

The Third-Party ICT Risk Management Guideline (hereinafter “Guideline”) establishes control requirements for DBAG and/or adopting Legal Entities within DBG (refers only to Legal Entities that have ratified the Guideline at hand) and provides criteria for fulfilling the control requirements.

The purpose of the Guideline is to effectuate the below listed Minimum Requirements, stipulated in the ICT Risk Management Policy (structured into Core Functions), acting as objectives to the Guideline and the control requirements at hand:

Core Function	Minimum Requirement	ICT Risk Management Policy chapter
Govern	2. Allocate roles and responsibilities as detailed in chapter 5 in this policy.	4.1
Govern	6. Have in place a mechanism to define and document responsibilities for implementing control requirements both within and outside IT and IS (e.g. HR). This can be documented e.g. as part of the ICT Control Framework (former Mandatory Control Framework (MCF)) .	4.1
Identify	4. Analyze relevant ICT risks in relation to third party relationships, taking into consideration the dependent functions and processes, and establish and agree appropriate safeguards.	4.2
Protect	1. Design and implement ICT risk management control requirements to achieve the protection goals and integrating them to the ICT Written Rules framework. These control requirements are including but not limited to ICT operations and physical and environmental security, network and infrastructure management, encryption and cryptographic controls, identity management and logical/physical access control, software development, change and project management, threat management, patch and vulnerability management, human resources, and third-party management, AI, IDP & NCLC¹, data management and other	4.3

¹ IDP refers to Individual Data Processing, and NCLC refers to No-Code/Low-Code solutions.

	controls addressing poor administration and human error risks.	
--	--	--

Table 1: Minimum Requirements

Note: The full list of Core Functions and Minimum Requirements is stipulated in the ICT Risk Management Policy.

1.2. Basis of this Guideline

The basis for this Guideline is the thematically linked ICT Risk Management Policy.

2. Functional Scope and Target Groups

2.1. Functional scope of applicability

Entity	DBAG and/or adopting LE within DBG
Area	DBAG CIO / COO Division; Chief Risk Officer Area; and any other area that manages or owns Third-Party ICT Risk Management topic

Table 2: Scope

2.2. Target groups

Within the scope of the current Third-Party ICT Risk Management Guideline below is addressed the list of applicable target groups and operation areas²:

Target group	Key message
ICT Risk Oversight	To oversee and provide complementary expertise, support, monitoring, and challenge related to the management of risk. To provide analysis and reports on the adequacy and effectiveness of third-party risk management (including internal control).
ICT Operational Management	To implement and maintain appropriate structures, processes, measures, and controls for the effective management of operations and third-party risk (including internal control).
Business Management	Leads and directs actions (including managing risk) and application of resources to achieve the objectives of the organization. To be accountable for the

² For LE Guidelines adoption process the target groups should be adjusted according to organizational structure of the LE.

	management of third-party ICT-risks affecting their business function or process. To decide on risk treatment (accept, transfer, avoid or mitigate the risk).
--	---

Table 3: Target groups

2.3. Transition period

The grace period for new requirements commences from the “valid from” date stated on the cover page. The compliance dates for control requirements defined in this version of the Guideline are defined as follows:

- For unchanged control requirements and new DORA requirements the compliance date equals the “valid from” date.
- For new and changed control requirements that are more stringent than before and are not subject to DORA, the compliance date is generally 90 calendar days after the “valid from” date unless otherwise stated in brackets after the control requirements. These control requirements are marked with ●.
- For Legal Entities that have not previously approved the IT-related requirements and are therefore addressing these requirements for the first time, a grace period of 90 days may be granted at the discretion of the Legal Entity. DORA requirements are exempt from this grace period.

For a **compliance date** exceeding a 180 calendar days implementation timeline, a Board approval is required.

3. Definitions

3.1. Requirements

Control requirement

The control requirements define the organizational, process or technical controls to be implemented by the control owner to achieve compliance with this Guideline.

Criteria

Criteria define the measures that 'must' or 'should' be taken to fulfill the control requirement.

Level of obligation

With respect to requirements and criteria, the following terms are used to define the level of obligation, provided for the implementation of a particular requirement or criteria:

- **“must”**: Mandatory control requirements / criteria derived directly from law, regulations, or internal specifications that the legal entity must comply with. Incompliance could result in consequences with external regulators and Internal Audit.
- **“should”**: Non-mandatory control requirements / criteria derived from best-practice frameworks or equivalent sources that the legal entity does not have to necessarily comply with. Under specific circumstances there may exist valid reasons to ignore a particular control requirement, but the full implications must be understood and carefully weighed.

Independent of the level of obligation of a given requirement or criteria, it is allowed to deviate from single requirements or criteria in individual cases. However, a control requirement deviation always requires the conduction of a risk assessment and risk management including adequate risk acceptance and/or mitigation.

Any deviation from the Guideline denotes an exemption. The respective Information Owner makes decisions on such exemptions. Information Owners can only decide on risks with impact exclusively in their area of responsibility.

Responsibilities

The responsibility for fulfilling control requirements may be distributed across the organization, e.g., multiple Sections, Units, or Departments. In some cases, one Unit may be responsible for both the design and implementation of measures. In other cases, one Unit may be responsible for the design of measures, and another Unit may be responsible for the implementation of the measures. In addition, multiple Units may be responsible to collectively fulfill one requirement.

The precise responsibilities are to be defined in the underlying Procedure documents (e.g. via RACI matrices).

The ICS, among its various functionalities, registers Process Operators (PO) and Risk Representatives (RRs) mapped to the corresponding processes, controls, and risks which the RRs and/or POs are responsible for managing on behalf of the part of the organization that utilize their services (e.g. Asset Owners). For more information on ICS, please refer to the DBG ICS Guideline.

3.2. Explanation of requirements and key definitions

Control requirements are defined in a standardized format and are structured into the following components:

<Specify ID: xx (version x)>	<Name of control requirement (e.g. Access to production data)>
1	<Description of the control requirement>
1.1 1.1.1	<Lists the criteria applying to the control requirement> <Lists the sub-criteria applying to the control requirement> Asset-Types: <Lists asset types applicable to the control requirement> Key references: <Lists key regulatory references and industry best practice requirements affecting this control requirement (e.g., ISO/IEC 27001:2022 A.5.10, A.8.1)>

The terms in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

4. Requirements

4.1. Requirements

ID: 1 (version 2.0)	Establishment of ICT third-party security management
1 DOR.ICT.TPR.GEN.001	ICT third-party relationship management must be documented and in place.
1.1 DOR.ICT.TPR.GEN.002	ICT third-party relationship management including documented processes and procedures must be established. The ICT third-party relationship management must address Information Security requirements and ensure protection of information assets of the legal entity. Asset-Types: Information, Business Process, Supplier Key References: DORA RTS RMF A.11.2k.iv)
1.2 DOR.ICT.TPR.GEN.003	ICT third-party relationship management must be integrated in the overall security measures and reflected in the risk assessment process; relevant ICT Risk Assessment and ICT Risk Management requirements are to be found in the ICT Risk Management Guideline. Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.28.1a)
1.3 DOR.ICT.TPR.GEN.004	The ICT third-party relationship management must consider: - Categories of ICT third-parties according to critical or important functions of the services/ products they provide to the legal entity, linked to the ICT Risk Management requirements - The inventory of the ICT third-party relationships in a register of all ICT Risk Management relevant ICT third-party relationships with the respective categories of services/ products as well as classification of the ICT third-party relationships. The register inventory should be aligned or merged with the register of information - The classification of criticality of information assets accessed by ICT third-party in the context of an ICT third-party relationship must be based on how information assets are accessed and handled (for more details – refer to the Third Party Risk Policy) Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.8.5
1.4 DOR.ICT.TPR.GEN.005	All processes with ICT third-party linkage including dependencies to critical and important functions must be identified and documented. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.19
1.5 DOR.ICT.TPR.GEN.006	Information Security requirements must be contractually agreed with each ICT third-party based on the type of ICT third-party relationship. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.19

1.6 DOR.ICT.TPR.GEN.007	Information Security requirements must reflect the whole lifecycle of the ICT third-party relationship – initiating, contracting, renewing, and renegotiating relationships as well as terminating the respective relationships. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.20
1.7 DOR.ICT.TPR.GEN.008	It must be contractually agreed and monitored that the Information Security requirements apply throughout the whole lifecycle of the ICT third-party relationship and to the whole supply chain. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.19
1.8 DOR.ICT.TPR.GEN.009	In cases where it is not possible for the legal entity to place requirements on an ICT third-party, the legal entity must implement compensating controls as necessary based on an ICT third-party risk assessment. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.19
1.9 DOR.ICT.TPR.GEN.010	All relevant information security requirements must be established and agreed with each ICT third-party according to the specifically identified ICT third-party risk classification. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.20
1.10 DOR.ICT.TPR.GEN.011	The information security requirements must reflect the legal entity internal information security controls and may vary according to the respective service or product type. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.20
1.11 DOR.ICT.TPR.GEN.012	ICT third-parties must be classified and registered according to critical or important functions and the following criteria based on a maximum principle across all services: - Critical: All regulatory outsourcing management relevant ICT third-parties and services or ICT third-parties with access to critical information - Major: All third-party management relevant ICT third-parties or ICT third-parties with access to information which is classified as major - Minor: All ICT third-parties with access to information which is classified as minor - Negligible: All other ICT third-parties or information Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.20

ID: 2 (version 2.0)	ICT third-party agreements
2 DOR.ICT.TPR.TPA.001	ICT third-party agreements must be documented and in place.
2.1 DOR.ICT.TPR.TPA.002	Contracts with ICT third-parties in scope with access to information assets of the legal entity must contain effective and enforceable control requirements for Information Security, based on ICT Risk Framework (for more details – refer to the ICT Risk Management Guideline) – based on Information Security Classification of ICT third-parties. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.20
2.2 DOR.ICT.TPR.TPA.003	Relevant contacts must be defined by both the ICT third-party and the legal entity, including a contact person for information security issues. For KRITIS-relevant assets the service provider must provide a 24x7 security contact for ICT-related Incidents. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.20
2.3 DOR.ICT.TPR.TPA.004	Contracts with ICT third-parties must be regularly reviewed (at least once a year), and reviewed if one of the following cases occurs and updated, if required: - In case of significant change of the ICT third-party relationship and/or ICT third-party organization and/or ICT third-party service - In case of significant change of ICT Risk Management Framework if required - In case of special request of relevant stakeholders (e.g. regulators, auditors) Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.20
2.4 DOR.ICT.TPR.TPA.005	If no update to agreements based on the review is needed, a confirmation must be documented. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.20
2.5 DOR.ICT.TPR.TPA.006	The Information Security requirements must be contractually agreed with the ICT third-party and documented, particularly including: - Security mechanisms, service levels descriptions (including updates and revisions thereof) and management requirements for all outsourced services - Description of the information to be provided or accessed and methods of providing or accessing the information - Mapping between the legal entity's information classification scheme and the information classification scheme of the ICT third-party - Applicable legal, statutory, regulatory, and contractual requirements, including a description of how it will be ensured that they are met

	- Relevant provisions for sub-contracting, including controls that need to be established, such as agreement on the use of sub-ICT third-parties - Indemnities and remediation for failure of contractor to meet requirements (except contracts between DBG entities) - Secure transfer of business information (for details refer to the Data Leakage Prevention Guideline) - Outsourced development requirement for an Asset Security Documentation for third-party developed applications, for a risk assessment for all third-party developed applications, for source code scans for third-party developed code following the same requirements as for internally developed source code. - Vulnerability reporting, handling and disclosure - Defect resolution and conflict resolution processes - Defined change management process that covers intervention possibility for the affected legal entity - Non-disclosure and confidentiality provisions as stated in ID 8 - ICT third-party employee screening requirements as stated in ID 5 - Training, awareness, and education measures of ICT third-party employees as stated in ID 6 - Comprehensive monitoring and review instruments including metrics for measuring adherence to information security requirements - Right to conduct periodic and ad hoc ICT third-party security audits based on the criticality of the ICT third-party (can be performed by a third-party or waived if the ICT third-party provides proof of applicable certification) - The implementation of a framework based on ICT Security Policies and Standards as well as best practices that comply with applicable ICT Security regulations and international standards, including the governance structure for ICT Security, roles & responsibilities, resources, policies, and processes - Compliance with state-of-the-art security standards for critical or important functions supporting ICT services - The implementation of effective controls to protect its assets associated with information and information processing facilities over its lifecycle - The implementation of management responsibilities and procedures for an effective and orderly response to ICT-related Incidents as well as the implementation of a Business Continuity Management - Definition and implementation of an Information Security framework - Locations of data processing and storage of ICT services and access to data and premises relating to ICT services supporting critical or important functions - Clauses to guarantee access, recovery and return in an easily obtainable format of personal and non-personal processed data in the event of insolvency, resolution or termination of the ICT third-party - Termination clauses upon conclusion of the agreement including records management, return of assets, secure disposal of information and other associated assets, handover support to another ICT third-party or to the legal entity itself, and any ongoing confidentiality obligation Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.20
2.6 DOR.ICT.TPR.TPA.007	A mechanism must be in place to govern the accessibility of contractually agreed information and evidences by both the ICT third-party and the legal entity, including evidences and assurance mechanisms of third-party

	attestations for relevant information security requirements related to the ICT third-party processes. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.20
2.7 DOR.ICT.TPR.TPA.008	Critical ICT third-parties must contractually agree to perform services in accordance with the legal entity's internal Information Security requirements for the framework based on ICT Security Policies and Standards. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.20
2.8 DOR.ICT.TPR.TPA.009	It must be ensured that evidences that are required by contract for the provided services are collected. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.20
2.9 DOR.ICT.TPR.TPA.010	Access rights for employees of ICT third-parties must be aligned with their services/ products and data access required in line with minimal needs or need-to-know principles; for logical access – refer to the Identity and Access Management Guideline). Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.15
2.10 DOR.ICT.TPR.TPA.011	Access rights for employees of ICT third-parties must be reviewed at least every 12 months and every 6 months for ICT Systems supporting critical or important functions. Access rights must be adjusted in case of changes in the role and/or accessed information. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.15

ID: 3 (version 2.0)	ICT third-party supply chain
3 DOR.ICT.TPR.SPC.001	The ICT third-party supply chain must be protected.
3.1 DOR.ICT.TPR.SPC.002	Information Security requirements and appropriate security practices must be defined for ICT product or service acquisition that are binding for the entire supply chain. Asset-Types: Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.21
3.2 DOR.ICT.TPR.SPC.003	Assurance must be obtained that delivered ICT products achieve the required security levels and are functioning as expected. Asset-Types: Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.21

3.3 DOR.ICT.TPR.SPC.004	Processes must be established for managing ICT component life cycle and the protection criteria (CIA) confidentiality, integrity, and availability. Asset-Types: Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.21
3.4 DOR.ICT.TPR.SPC.005	Processes must be established for managing security risks associated with components not being longer available or ICT third-parties no longer providing these components. Asset-Types: Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.21

ID: 4 (version 2.0)	Monitoring, review and change management of ICT third-party services
4 DOR.ICT.TPR.MRC.001	Monitoring, review and change management procedures for ICT third-party services must be documented and in place.
4.1 DOR.ICT.TPR.MRC.002	ICT third-parties and their provided services must be monitored with agreed instruments implemented within the entire ICT third-party lifecycle management process. Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.28.6
4.2 DOR.ICT.TPR.MRC.003	It must be ensured that ICT third-parties and services are reviewed according to their criticality based on the information security classification of ICT third-parties. Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.28.6
4.3 DOR.ICT.TPR.MRC.004	ICT third-party service delivery regarding the contractually agreed information security requirements must be reviewed and documented at least every 12 months and in if the following events occur: - In case of significant change of the ICT third-party relationship and/or ICT third-party organization and/or ICT third-party service - In case of significant change of ICT Risk Framework if required - In case of special request of relevant stakeholders (e.g. regulators, auditors) - In case of major ICT-related Incident (for more details – refer to the ICT Incident & Operational Event Management Guideline) Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.28.6
4.4 DOR.ICT.TPR.MRC.005	Responsibility for managing ICT third-party relationships must be assigned to a dedicated individual or team with sufficient professional and technical skills and resources to monitor that the requirements, in particular the information security requirements, are being met.

	Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.28.6
4.5 DOR.ICT.TPR.MRC.006	It must be ensured that the ICT third-parties' and sub-ICT third-parties' services and security capabilities can be audited or at least assessed through ICT third-parties' self-assessments, based on a risk-based approach. Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.28.6
4.6 DOR.ICT.TPR.MRC.007	Risk mitigation procedures and audit procedures must be defined and implemented if one criterion does not fit. Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.28.6
4.7 DOR.ICT.TPR.MRC.008	It must be ensured, on an ongoing basis, that ICT third-party arrangements meet appropriate performance and quality standards in line with the agreed framework. Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.28.6
4.8 DOR.ICT.TPR.MRC.009	Regarding controlling and monitoring of ICT third-parties, it must be ensured to monitor compliance with applicable legal and regulatory requirements as stated. Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.28.6
4.9 DOR.ICT.TPR.MRC.010	It must be ensured to include the results of the monitoring in the review of the third-party's risk assessment. Identified violations and deviations are subjected to analysis, evaluation, and treatment in accordance with the risk management procedure. Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.28.6
4.10 DOR.ICT.TPR.MRC.011	Key Performance Indicators reporting that are delivered by the ICT third-party must be reviewed depending on their contractually agreed KPI delivery (Assessment if the Information Security provisions of the agreements are being adhered to and that ICT-related Incidents and problems are managed properly). Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.28.6
4.11 DOR.ICT.TPR.MRC.012	Assurance of the ICT third-party's cyber resilience capabilities must be obtained if relevant for services/criticality. Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.28.6
4.12 DOR.ICT.TPR.MRC.013	A process to manage the relationship between the legal entity and the ICT third-party must be established to ensure that ICT-related Incidents and problems are managed properly, including: - Provision of information about ICT events or ICT-related Incidents and review of this information

	- Identification and management of information security vulnerabilities - Conduction of penetration tests to assess the effectiveness of implemented cyber and internal ICT security measures if relevant for services/criticality - Sufficient service capability together with workable plans designed to ensure that agreed service continuity levels are maintained following major service failures or disaster Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.28.6
4.13 DOR.ICT.TPR.MRC.014	Changes to the provision of services by ICT third-parties, including maintaining and improving existing Information Security policies, procedures, and controls, must be managed, taking account of the criticality of business information, ICT Systems and processes involved and the re-assessment of risks. Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.28.6
4.14 DOR.ICT.TPR.MRC.015	It must be ensured that any changes in ICT third-parties services initiate a classification review (as stated in ID 1) of the ICT third-party and classification is adjusted, if needed. Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.28.6

ID: 5 (version 2.0)	ICT third-party screening
5 DOR.ICT.TPR.SCR.001	Screening of ICT third-parties must be documented and in place.
5.1 DOR.ICT.TPR.SCR.002	Contractual arrangements between the legal entity and the ICT third-party must specify the responsibilities of the ICT third-party for conducting background checks for all employees who have access to the legal entity's data and ICT Systems. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.6.1
5.2 DOR.ICT.TPR.SCR.003	It must be documented in writing that a background check has been performed for the employees assigned by the ICT third-party (incl. sub-ICT third-parties) prior to the start of their work for the legal entity. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.6.1
5.3 DOR.ICT.TPR.SCR.004	Information Security responsibilities of the legal entity must be communicated to all ICT third-parties prior to the commencement of their respective contract. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.6.2

ID: 6 (version 2.0)	Information security awareness, education, and training of ICT third-parties
6 DOR.ICT.TPR.ISA.001	Information security awareness, education and trainings for ICT third-parties must be documented and in place.
6.1 DOR.ICT.TPR.ISA.002	It must be contractually agreed that the ICT third-party must only assign professionally qualified employee to the legal entity. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.6.3
6.2 DOR.ICT.TPR.ISA.003	It must be documented in writing that the employees assigned by the ICT third-party have appropriate qualifications before starting their work for the legal entity. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.6.3
6.3 DOR.ICT.TPR.ISA.004	It must be contractually agreed that the ICT third-party must train its assigned employees regularly in relation to the requirements of Information Security and must inform them about special Information Security requirements of the legal entity prior to employment. The communicated information security controls to the respective employees must be at least those contractually agreed upon. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.6.3
6.4 DOR.ICT.TPR.ISA.005	It must be contractually agreed that the ICT third-party participates in the legal entity's ICT security awareness programs and digital operational resilience training. Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.30.2i)

ID: 7 (version 2.0)	Offboarding or change of Third-Party
7 DOR.ICT.TPR.OFF.001	A secure procedure for offboarding of third-party or change of third-party must be documented and in place.
7.1 DOR.ICT.TPR.OFF.002	It must be contractually agreed upon the possibility of terminating the arrangement in the following cases: Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.28.7a), A.30.2d)
7.1.1 DOR.ICT.TPR.OFF.003	Substantial violation of relevant laws, rules, or contractual provisions by the ICT third-party. Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.28.7a), A.30.2d)
7.1.2	Events found during the monitoring of ICT third-party risk that have the potential to change how the functions provided by the contractual

DOR.ICT.TPR.OFF.004	arrangement are performed, such as significant modifications that impact the arrangement or the circumstances of the ICT third-party. Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.28.7b), A.30.2d)
7.1.3 DOR.ICT.TPR.OFF.005	Weaknesses regarding the management and security (availability, authenticity, integrity and, confidentiality) of confidential, personal, or otherwise sensitive data or information on the part of the ICT third-party. Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.28.7c), A.30.2d)
7.1.4 DOR.ICT.TPR.OFF.006	The competent authority is no longer capable of properly supervising the legal entity due to the circumstances of the contractual obligations with the ICT third-party. Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.28.d), A.28.2d)
7.2 DOR.ICT.TPR.OFF.007	Contractual obligations with ICT third-parties must ensure that Information Security requirements are followed for a defined period after the termination of their contract to ensure orderly transfer of the function in the event of the termination. Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.30.2d)
7.3 DOR.ICT.TPR.OFF.008	Access management processes must ensure a rapid off-boarding of employees of ICT third-parties as soon as possible (for logical access – refer to the Identity and Access Management Guideline). Asset-Types: Information, Business Process, Supplier Key References: DORA 2022/2554 A.30.2d)

ID: 8 (version 2.0)	Confidentiality or non-disclosure agreements
8 DOR.ICT.TPR.NDA.001	Confidentiality or non-disclosure agreements must be documented and in place.
8.1 DOR.ICT.TPR.NDA.002	All information, based on its confidentiality, which are exchanged with a ICT third-party within the legal entity's internal network and leaving the legal entity's internal network must be protected in transit, either physically or logically, by both the ICT third-party and the legal entity using legal entity approved Cryptographic Measures; for more details – refer to the Encryption and Key Management Guideline. Asset-Types: Information, Business Process, Certificate, Storage Media, Network Connection, Supplier Key References: ISO 27001:2022 Cor 202203 A.6.6
8.2 DOR.ICT.TPR.NDA.003	It must be ensured that the ICT third-party complies with the requirements for the secure exchange of information between the ICT third-party and the legal entity, both within the legal entity's internal network and leaving the legal

	entity's internal network; for more details – refer to the Identity and Access Management Guideline. Asset-Types: Information, Business Process, Certificate, Storage Media, Network Connection, Supplier Key References: ISO 27001:2022 Cor 202203 A.6.6
8.3 DOR.ICT.TPR.NDA.004	Information Security requirements on confidentiality and non-disclosure reflecting the organisation's needs for the protection of information must be reviewed and updated at least once every 12 months and ad hoc, if necessary. Asset-Types: Information, Business Process, Certificate, Storage Media, Network Connection, Supplier Key References: ISO 27001:2022 Cor 202203 A.6.6
8.4 DOR.ICT.TPR.NDA.005	ICT third-party non-disclosure provisions containing Information Security requirements must be in place prior to being given access for the ICT third-party to information and other associated assets. The requirements to protect confidential information must be addressed using legally enforceable terms. Asset-Types: Information, Business Process, Certificate, Storage Media, Network Connection, Supplier Key References: ISO 27001:2022 Cor 202203 A.6.6
8.5 DOR.ICT.TPR.NDA.006	Contracts with ICT third-parties who have access to information assets of the legal entity must contain effective and enforceable confidentiality provisions containing Information Security requirements. These confidentiality terms must be in place throughout the whole ICT third-party relationship lifecycle and must be reviewed at least once every 12 months. Asset-Types: Information, Business Process, Certificate, Storage Media, Network Connection, Supplier Key References: ISO 27001:2022 Cor 202203 A.6.6
8.6 DOR.ICT.TPR.NDA.007	Information Security requirements on confidentiality and non-disclosure must be defined according to: - Necessary level of confidentiality of documents accessed by the respective ICT third-party; the determination of confidentiality is to be found in the Data Leakage Prevention Guideline - Criticality of information assets accessed by the respective ICT third-party. The determination of criticality is to be found in the ICT Risk Management - Access permission to documents and information assets; for more details - refer to the Identity and Access Management Guideline Asset-Types: Information, Business Process, Certificate, Storage Media, Network Connection, Supplier Key References: ISO 27001:2022 Cor 202203 A.6.6

ID: 9 (version 2.0)	Additional control requirements applicable for CSSF regulated legal entities
9 DOR.ICT.TPR.ADD.001	Additional control requirements for CCSF regulated legal entities must be documented and in place.
9.1 DOR.ICT.TPR.ADD.002	When a CSSF regulated legal entity intends to outsource a critical or important function, the competent authority must be notified at least three (3) months before the planned outsourcing comes into effect. If the CSP and the resource operation are authorized according to CSSF, the competent authority must be notified at least one (1) month before. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.5
9.2 DOR.ICT.TPR.ADD.003	The competent authority must be notified in case of changes to the outsourcing of critical or important functions as well as when terminating outsourcing of critical or important functions. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.5
9.3 DOR.ICT.TPR.ADD.004	Any notification to the competent authority must be submitted by using the forms available on the CSSF website. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.5
9.4 DOR.ICT.TPR.ADD.005	Before entering into any outsourcing arrangement, legal entities must undertake appropriate due diligence on the prospective ICT third-party. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.5

ID: 10 (version 2.0)	Third Party ICT Risk Management for Cloud Service Providers
10 DOR.ICT.TPR.CSP.001	Additional control requirements for Cloud Service Providers must be documented and in place.
10.1 DOR.ICT.TPR.CSP.002	The legal entity must maintain an inventory for controlling and monitoring the service providers and ICT third-parties who contribute services to the delivery of the cloud service. The following information must be maintained in the inventory: - Company name - Address - Locations of data processing and storage - Responsible contact person at the CSP and roles and contact details of individuals responsible for supporting the cloud service within the organisation (e.g. business owners and individuals responsible for administering and securing the cloud service) and the CSP (e.g. commercial and technical advisors) - Classification based on the risk assessment

	- The criticality of the business processes they support - Description of the services and main cloud features used (e.g. private or public cloud; IaaS, PaaS or SaaS; and type of cloud management console) - Beginning of service usage - Proof of compliance with contractually agreed requirements Asset-Types: Information, Business Process, Cloud Appliance, Cloud PaaS, Supplier Key References: DORA RTS RMF A.11.2kiii)
10.2 DOR.ICT.TPR.CSP.003	Roles and responsibilities for protecting the cloud environment must be agreed, including shared responsibilities and the need for collaboration, which may be the responsibility of: - CSPs, such as securing the underlying cloud infrastructure, the backend services and physical infrastructure - The organisation itself, such as for securing its personal data, performing user management, and securely configuring ICT Systems - Other external ICT third-parties (e.g. Cloud Access Security Brokers (CASBs), Identity as a Service (IDaaS) ICT third-parties or network service providers), such as for providing specific cloud or generic network services Asset-Types: Information, Business Process, Supplier Key References: DORA RTS RMF A.11.2kii)
10.3 DOR.ICT.TPR.CSP.004	Mandatory onsite inspection must be carried out in regular intervals depending on the existence of material workload or not. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.22
10.4 DOR.ICT.TPR.CSP.005	The legal entity must have access to the staff of the cloud computing service provider, subject to prior notification within a reasonable time frame. This is for queries, interviews, or audit. Asset-Types: Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.22
10.5 DOR.ICT.TPR.CSP.006	The legal entity must have access to the relevant documentation of the cloud computing service provider (this documentation must notably include audit reports, certification reports, policies and procedures). Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.22
10.6 DOR.ICT.TPR.CSP.007	The legal entity must have the possibility to communicate observations to the supervised institution (ISCR and resource operator). Asset-Types: Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.22
10.7 DOR.ICT.TPR.CSP.008	The legal entity must establish architecture Guidelines and best practices for the use of cloud services to get the right balance between usage of cloud native services and avoidance of lock in by providing the required interoperability and portability where needed.

	Asset-Types: Information, Business Process, Cloud Appliance, Cloud PaaS, Cloud IaaS Key References: ISO 27001:2022 Cor 202203 A.5.22
10.8 DOR.ICT.TPR.CSP.009	The CSP must communicate to the legal entity about changes that could have a significant impact on the IT Asset functionality used by the legal entity (exception: the changes relating to corrective maintenance), prior to its implementation, so that the legal entity may take the necessary measures in case of material change or discontinuity. Asset-Types: Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.22
10.9 DOR.ICT.TPR.CSP.010	The legal entity must have access to the institution's data and ICT Systems hosted on a cloud computing infrastructure. This access must be managed by the resource operator. Access should be provided during an audit performed by the legal entity or regulator but not on an ongoing basis. Asset-Types: Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.22
10.10 DOR.ICT.TPR.CSP.011	The legal entity must ensure interoperability and portability of IT Assets, namely their capacity to exchange information and mutually use the information. Asset-Types: Information, Business Process, Cloud Appliance, SaaS, Cloud IaaS, Cloud PaaS, Storage, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.22
10.11 DOR.ICT.TPR.CSP.012	The legal entity must take the necessary measures to be in a position to adequately transfer the outsourced activities into a cloud computing infrastructure to a different provider or to perform those activities itself whenever the continuity or quality of the service provision is likely to be affected. Asset-Types: Information, Business Process, Cloud Appliance, SaaS, Cloud IaaS, Cloud PaaS, Storage, Supplier Key References: DORA RTS RMF A.11.2 ka
10.12 DOR.ICT.TPR.CSP.013	Deletion of legal entity owned data and IT Assets must be possible. Asset-Types: Information, Business Process, Cloud Appliance, SaaS, Cloud IaaS, Cloud PaaS, Storage, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.22
10.13 DOR.ICT.TPR.CSP.014	The legal entity must ensure protection of the data concerned by outsourcing in accordance with the General Data Protection Regulation (GDPR) and with the requirements of the authority competent in this matter, e.g. the National Commission for Data Protection (CNPD). Asset-Types: Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.22
10.14 DOR.ICT.TPR.CSP.015	The legal entity must ensure that its data is only stored and processed in countries in line with legal entity and legal requirements (for details regarding enforcing and monitoring regulatory requirements, please refer to the Outsourcing & Third Party Risk Policy).

	Asset-Types: Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.22
10.15 DOR.ICT.TPR.CSP.016	A process must be implemented that ensures for third-party information requests (e.g. governmental information requests or requests in case of legal causes), that any request is assessed against a valid legal basis, only data that is required for the specific investigation is made accessible and that the legal entity will be informed in such cases when legally permitted. Asset-Types: Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.22
10.16 DOR.ICT.TPR.CSP.017	Based on the different service models of the cloud services, the legal entity must implement the appropriate security controls, vendor recommended settings and assign an appropriate owner and document them as a basis for the risk assessment. Asset-Types: Business Process, Supplier Key References: DORA RTS RMF A.11.2ki)
10.17 DOR.ICT.TPR.CSP.018	There must be controls for secure procurement of resources in line with requirements of the legal entity. Asset-Types: Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.22
10.18 DOR.ICT.TPR.CSP.019	For critical cloud components like virtualization software etc., which cannot be validated by the legal entity according to baselines (since they are managed by the CSP), it must be contractually agreed that the CSP has to ensure appropriate patching and hardening. Asset-Types: Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.22
10.19 DOR.ICT.TPR.CSP.020	The legal entity must ensure through contractually agreed reports provided by the CSP to verify the procedures for monitoring compliance with the requirements relating to the following aspects: - Configuration of ICT System components - Performance and availability of ICT System components - Response time to malfunctions and ICT-related Incidents - Recovery time (time until completion of error handling) Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.22
10.20 DOR.ICT.TPR.CSP.021	The legal entity must ensure that all cloud resources (owning and using assets) are automatically and regularly monitored in accordance with business objectives, security requirements, and compliance obligations. If a baseline deviation is identified the Asset Owner must be notified. All baseline deviations must be remediated by the Asset Owner. Monitoring must include: - Managing vulnerabilities by performing vulnerability scanning, conducting regular penetration tests, considering crowdsourced penetration testing and carrying out code reviews - Extending security event management into the cloud environment by using a cloud-based security information and event management (SIEM) platform, connecting the cloud environment to an on-premises SIEM and/or leveraging a managed security service provider (MSSP)

	- Integrating the use of cloud services into an appropriate ICT-related Incident management process through creating a cloud ICT-related Incident management capability, establishing a cloud ICT-related Incident management process, and developing cloud service-specific ICT-related Incident Management plans - Accordance with the contractual agreements, for example regarding compliance with SLAs Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.22, BaFin Aufsichtsmittelung Outsourcing to the cloud
--	---

ID: 11 (version 2.0)	Additional cloud-related control requirements applicable for CSSF regulated legal entities
11 DOR.ICT.TPR.RLE.001	Additional control requirements for CSSF regulated legal entities must be documented and in place.
11.1 DOR.ICT.TPR.RLE.002	Legal entities using cloud services must designate a qualified Cloud Officer. Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.5.5
11.2 DOR.ICT.TPR.RLE.003	Outsourced activities must be specified as material or non-material within the cloud computing infrastructure outsourcing register / inventory. Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.5.5
11.3 DOR.ICT.TPR.RLE.004	The cloud computing infrastructure outsourcing register / inventory must be transmitted to the competent authority upon request. Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.5.5

ID: 12 (version 2.0)	Additional control requirements on Outsourcing to Cloud Service Providers.
12 DOR.ICT.TPR.OUT.001	Additional control requirements must be documented and in place for outsourcing to Cloud Service Providers.
12.1 DOR.ICT.TPR.OUT.002	It should be decided individually, which information from those layers that are the responsibility of the cloud provider should also be included in the CMDB of the supervised entity. Asset-Types: Information, Business Process, SaaS, Cloud Appliance, Cloud PaaS Key References: BaFin Aufsichtsmittelung zu Auslagerungen an Cloud Anbieter V.1
12.2 DOR.ICT.TPR.OUT.003	The legal entity must put in place policies on the use of cloud services that span both overarching requirements applicable to all service providers and associated services as well as provisions applicable to specific providers and services.

	Asset-Types: Information, Business Process Key References: BaFin Aufsichtsmittelung zu Auslagerungen an Cloud Anbieter III.3
12.3 DOR.ICT.TPR.OUT.004	The policies for cloud use must at least cover the topics of cloud compliance, identity and access management, encryption and key management, development and operation, hardening of applications, interfaces and environments, control of subcontractors and IT emergency management. Asset-Types: Information, Business Process Key References: BaFin Aufsichtsmittelung zu Auslagerungen an Cloud Anbieter III.3
12.4 DOR.ICT.TPR.OUT.005	The legal entity must maintain sufficient quantitative and qualitative resources for the use of the cloud and anchor them organizationally (human, financial and other resources). This applies in particular to governance, risk management and outsourcing management. Asset-Types: Business Process, Cloud Appliance, Cloud PaaS, Cloud IaaS, Cloud SaaS Key References: BaFin Aufsichtsmittelung zu Auslagerungen an Cloud Anbieter III.4
12.5 DOR.ICT.TPR.OUT.006	The legal entity must ensure that employees in charge of tasks related to cloud have appropriate and relevant skills and knowledge of how the cloud works, the risks associated with it and the technical and organizational peculiarities of cloud operation. The more technical the tasks, the more specific the knowledge of the cloud provider and the cloud services should be. Asset-Types: Information, Business Process Key References: BaFin Aufsichtsmittelung zu Auslagerungen an Cloud Anbieter III.4
12.6 DOR.ICT.TPR.OUT.007	The legal entity must specify (architectural) requirements in the cloud to be able to implement them technically when developing cloud applications and configuring cloud environments. Asset-Types: Information, Business Process Key References: BaFin Aufsichtsmittelung zu Auslagerungen an Cloud Anbieter IV.1.3
12.7 DOR.ICT.TPR.OUT.008	Backups of business-critical data and configurations must be documented and also be stored outside the affected cloud at regular intervals, e.g. on-premise or with another cloud provider. Asset-Types: Information, Business Process, SaaS, Cloud Appliance, Cloud PaaS, Supplier Key References: BaFin Aufsichtsmittelung zu Auslagerungen an Cloud Anbieter IV.2
12.8 DOR.ICT.TPR.OUT.009	If a joint test of the ICT continuity plans with the cloud provider is not possible, it must be ensured that all affected components are adequately covered by own tests or by appropriate test evidence. Asset-Types: Information, Business Process, SaaS, Cloud Appliance, Cloud PaaS, Supplier Key References: BaFin Aufsichtsmittelung zu Auslagerungen an Cloud Anbieter IV.3
12.9 DOR.ICT.TPR.OUT.010	In the information domain where all primary and secondary assets are mapped, all layers that under the shared responsibility model fall under the responsibility of the covered legal entity must be displayed. Asset-Types: Information, Business Process Key References: BaFin Aufsichtsmittelung zu Auslagerungen an Cloud Anbieter V.1

12.10 DOR.ICT.TPR.OUT.011	The covered legal entity must define and document tasks and responsibilities in relation to the operational functions and activities in its information domain for all cloud services used. Asset-Types: Information, Business Process Key References: BaFin Aufsichtsmittelung zu Auslagerungen an Cloud Anbieter V.1
12.11 DOR.ICT.TPR.OUT.012	Service agreements with cloud service providers must include provisions limiting changes directly impacting covered legal entity owned environments/tenants to explicitly authorized requests within service level agreements between CSPs and the covered legal entity. Asset-Types: Information, Business Process, Supplier Key References: CCM requirement CCC05
12.12 DOR.ICT.TPR.OUT.013	Policies and procedures must be in place for interoperability and portability of application interfaces, information processing, application development, data exchange and include requirements for: - Communications between application interfaces - Information processing interoperability - Application development portability Information/Data exchange, usage, portability, integrity, and persistence Asset-Types: Information, Business Process, Supplier Key References: CCM requirement IPY01
12.13 DOR.ICT.TPR.OUT.014	It must be contractually ensured that covered legal entity has access to data upon contract termination with the cloud service provider. Provisions must include at least: - Data format - Length of time the data will be stored - Scope of the data retained and made available to the CSCs - Data deletion policy Asset-Types: Information, Business Process, Supplier Key References: CCM requirement IPY04

ID: 13 (version 2.0)	ICT Third-Party Software Development
13 DOR.ICT.TPR.SWD.001	It must be ensured that measures are documented and in place for ICT Third-Party Software Development.
13.1 DOR.ICT.TPR.SWD.002	Equivalent security measures must be applied to outsourced software development as to legal entity software development (for more details – refer to the Software Development and ICT Change Management Guideline). Asset-Types: Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.8.30
13.2 DOR.ICT.TPR.SWD.003	Ensure that outsourced development must be adequately evaluated and handled.

	Asset-Types: Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.8.30
--	---

5. Roles and Responsibilities

5.1. Creator

The creator of the Third-Party ICT Risk Management Guideline is the **ICT Risk Governance & Advisory** Unit (Specialist).

The creator of Third-Party ICT Risk Management Guideline has the responsibility to issue clear, precise, and appropriate written rules to give guidance for implementation to the target group. It is important to ensure that all required information is accurate, up to date and complete.

5.2. Guideline Owner

The owner of the Third-Party ICT Risk Management Guideline is Head of **ICT Risk Governance & Advisory** Unit.

The most important tasks (not an exhaustive list) within the scope of responsibility are:

- Ensure completeness of the Guideline within functional area of responsibility
- Ensure correctness of content and the Guideline is up to date
- Define and conduct adherence oversight measures for Guidelines on a regular basis
- Assess impact on the Guideline with major focus on requirements as well as roles and responsibilities in the event of organizational changes, new products etc.

The Guideline Owner has at least an Expert or Head of Unit level.

The Guideline Owner is responsible for publishing and updating the Third-Party ICT Risk Management Guideline according to established procedures within the organization.

6. Appendix

6.1. Contact Information

Written Rule Owner: Head of ICT Risk Governance & Advisory Unit

Please contact **ICT Risk Governance & Advisory** in case of any questions related to this Guideline.

6.2. Document History

Document History

Version	Date	Changes & Background
1.0	17.01.2025	Initial set-up of this Guideline
1.1	15.08.2025	Annual Update Guideline
2.0	19.08.2026	Annual Update with material changes

Coordination before publication

Version	Date	Task	Name
2.0	15.05.2026	Creator	ICT Risk Governance & Advisory Unit (Specialist)
	28.07.2026	Content Review	LE CISOs TISOs IT Ameli project
	28.07.2026	Content Confirmation	Head of ICT Risk Governance & Advisory Unit and LE CISOs

Approvals

Version	Date	Task	Name
2.0	13.08.2026	Approval	DBAG Chief Risk Officer

6.3. Related Written Rules

Superordinated Written Rules	- ICT Risk Management Policy - Outsourcing & Third Party Risk Policy
Subordinated Written Rules	n/a

6.4. Abbreviations

The abbreviations in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

***** END OF DOCUMENT *****
